ZETA-Guard Bewertung von potenziellen Schwachstellen

Betrachtet werden CVEs der Schwere CRITICAL und HIGH

- Images
  - PDP / Keycloak
  - Keycloak-DB / Postgres
  - PEP / NGINX
  - Telemetrie
  - k8s.io/ingress-nginx
  - zeta-testenv-staging-ingress-nginx-controller
- Notes
  - Fetch image-names
  - Check cluster
  - CI Jobs

Images aus Helm Chart 0.3.2

PDP / Keycloak

Image: ".../zeta/zeta-guard/keycloak-zeta:main"

protobuf-java-3.25.1.jar	CVE-2024-7254	HIGH	Wird nicht verwendet
java-21-openjdk-headless	CVE-2025-66293	HIGH	Wird nicht verwendet Image-Processing wird nicht genutzt
java-21-openjdk-headless	CVE-2026-22184	HIGH	false positive: untgz ist nicht im Image enthalten.
com.microsoft.sqlserver:mssql-jdbc	CVE-2025-59250	HIGH	Wird nicht verwendet MSSQL wird verwendet

PDP OPA

Image: “openpolicyagent/opa:1.11.0-static“

stdlib	CVE-2025-68121	CRITICAL	TLS wird momentan nicht verwendet und zukünftig vom Service Mesh umgesetzt. Deshalb keine Relevanz.
stdlib	CVE-2025-61726	HIGH	Neubewertung img eingesetzen Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:L/MAC:X/MPR:X/MUI:R/MS:U/MC:X/MI:X/MA:X
stdlib	CVE-2025-61728	HIGH	Im Kontext passende Neubewertung durch CISA-ADP ist MEDIUM: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H
stdlib	CVE-2025-61729	HIGH	Neubewertung im eingesetzen Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:X/MAC:H/MPR:H/MUI:X/MS:X/MC:X/MI:X/MA:X
stdlib	CVE-2025-61730	HIGH	TLS wird momentan nicht verwendet und zukünftig vom Service Mesh umgesetzt. Deshalb keine Relevanz.

PEP / NGINX

Image: “.../zeta/zeta-guard/ngx_pep:main"

libpng16-16	CVE-2026-22695 CVE-2026-22801	HIGH	Wird nicht verwendet Image-Processing wird nicht genutzt

	CVE-2026-25646		
libxslt1.1	CVE-2025-7425	HIGH	Wird nicht verwendet – kein XSLT
libc-bin, libc6	CVE-2026-0861	HIGH	Warte auf Upstream Fix https://security-tracker.debian.org/tracker/CVE-2026-0861 für trixie. Für produktive Images käme hier vmtl. ein Hotfix.
stdlib	CVE-2025-68121	CRITICAL	TLS wird momentan nicht verwendet und zukünftig vom Service Mesh umgesetzt. Deshalb keine Relevanz.
stdlib	CVE-2025-61726	HIGH	Neubewertung img eingesetzen Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:L/MAC:X/MPR:X/MUI:R/MS:U/MC:X/MI:X/MA:X
stdlib	CVE-2025-61728	HIGH	Im Kontext passende Neubewertung durch CISA-ADP ist MEDIUM: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H
stdlib	CVE-2025-61729	HIGH	Neubewertung im eingesetzen Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:X/MAC:H/MPR:H/MUI:X/MS:X/MC:X/MI:X/MA:X
stdlib	CVE-2025-61730	HIGH	TLS wird momentan nicht verwendet und zukünftig vom

			Service Mesh umgesetzt. Deshalb keine Relevanz.

Ingress Controller (F5 nginx-ingress)

Image: “docker.io/nginx/nginx-ingress:5.3.2“

libpng16-16	CVE-2026-22695 CVE-2026-22801 CVE-2026-25646	HIGH	Wird nicht verwendet Image-Processing wird nicht genutzt
libxslt1.1	CVE-2025-7425	HIGH	Wird nicht verwendet – kein XSLT
libc-bin, libc6	CVE-2026-0861	HIGH	Warte auf Upstream Fix https://security-tracker.debian.org/tracker/CVE-2026-0861 für trixie. Für produktive Images käme hier vmtl. ein Hotfix.
stdlib	CVE-2025-68121	CRITICAL	(es geht hier um interne TLS für die Telemetriedaten) TLS wird momentan nicht verwendet und zukünftig vom Service Mesh umgesetzt. Deshalb keine Relevanz.
stdlib	CVE-2025-61726	HIGH	(es geht hier um interne Verbindungen für die Telemetriedaten) Neubewertung im eingesetzen Kontext

			ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:L/MAC:X/MPR:X/MUI:R/MS:U/MC:X/MI:X/MA:X
stdlib	CVE-2025-61728	HIGH	Im Kontext passende Neubewertung durch CISA-ADP ist MEDIUM: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H
stdlib	CVE-2025-61730	HIGH	(es geht hier um interne TLS für die Telemetriedaten) TLS wird momentan nicht verwendet und zukünftig vom Service Mesh umgesetzt. Deshalb keine Relevanz.

Keycloak-DB / Postgres

Image: “ghcr.io/zalando/spilo-16:3.2-p2“

Anmerkung: Wird durch cloudnative-pg ersetzt.

gnupg, dirmng, gnupg-l10n, gnupg-utils, gpg, gpgp-agent, gpgp-wks-client, gpg-wks-server, gpgpconf, gpgsm, gpgv	CVE-2025-68973	HIGH	gnupg wird nicht verwendet
libtiff5	CVE-2025-9900	HIGH	Keine Bildverarbeitung durch die Datenbank.

rsync	CVE-2024-12084	HIGH	rsync wird nicht verwendet.
protobuf	CVE-2025-4565 CVE-2026-0994	HIGH	• CVE-2025-4565: Bewertung durch NVD ist MEDIUM: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L • CVE-2026-0994: Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:L/MAC:X/MPR:X/MUI:R/MS:U/MC:X/MI:X/MA:X
github.com/dgrijalva/jwt-go	CVE-2020-26160	HIGH	Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
github.com/golang-jwt/jwt	CVE-2025-30204	HIGH	Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
github.com/jackc/pgx	CVE-2024-27289	HIGH	Nicht ausnutzbar, weil SQL Injection schon vorher verhindert wird. Wird trotzdem bei Wechsel auf cloudnative-pg angegangen.
github.com/jackc/pgx http://github.com/jackc/pgproto3/v2	CVE-2024-27304 auch bekannt als GHSA-	CRITICAL	Wir gehen davon aus, dass der ZETA Guard noch nicht produktiv eingesetz wird. Dann reduziert sich mit folgender Neubewertung der CVSS3.1 Score auf MEDIUM

	7jwh-3vrq-q3m8		AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/CR:L/IR:L/AR:L/MAV:X/MAC:X/MPR:L/MUI:X/MS:X/MC:X/MI:X/MA:X Wird bei Wechsel auf cloudnative-pg angegangen.
golang.org/x/crypto	CVE-2024-45337	CRITICAL	Nicht verwendet.
golang.org/x/crypto	CVE-2025-22869	HIGH	SSH wird nicht verwendet.
golang.org/x/net	CVE-2022-27664 CVE-2022-41723 CVE-2023-39325	HIGH	• CVE-2022-27664: Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X • CVE-2022-41723: Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X • CVE-2023-39325: Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
golang.org/x/oauth2	CVE-2025-22868	HIGH	Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/

			A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
golang.org/x/text	CVE-2022-32149	HIGH	Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
google.golang.org/grpc	GHSA-m425-mq94-257g	HIGH	Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
gopkg.in/yaml.v3	CVE-2022-28948	HIGH	Neubewertung im eingesetzen Kontext nach CVSS3.1 ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
stdlib	CVE-2024-24790 CVE-2025-68121	CRITICAL	• CVE-2024-24790: Neubewertung im eingesetzen Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/CR:X/IR:L/AR:L/MAV:A/MAC:H/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X • CVE-2025-68121: Neubewertung im eingesetzen Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N/CR:X/IR:X/AR:L/MAV:A/MAC:H/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
stdlib	CVE-2023-45288	HIGH	• CVE-2023-45288: Neubewertung im eingesetzen

	CVE-2024-34156 CVE-2025-47907 CVE-2025-58183 CVE-2025-61726 CVE-2025-61728 CVE-2025-61729 CVE-2025-61730		Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X • CVE-2024-34156: Neubewertung im eingesetzen Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X • CVE-2025-47907: Neubewertung im eingesetzen Kontext ist MEDIUM: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:L/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X • CVE-2025-58183: Bewertung von CISA-ADP ist MEDIUM: AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:L • CVE-2025-61726: Neubewertung im eingesetzen Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X • CVE-2025-61728: Bewertung von CISA-ADP ist MEDIUM: AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H • CVE-2025-61729: Neubewertung im eingesetzen Kontext ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H/CR:X/IR:X/AR:X/MAV:A/M

			AC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X • CVE-2025-61730: Bewertung von CISA-ADP ist MEDIUM: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N